SOX / ICFR Engagement

Product Requirements Document

Contents

1 · Introduction

In the US, public companies must prove every year that the controls protecting their financial numbers work. This is the Sarbanes Oxley Act, section 404. Management signs a statement saying the controls are effective, and for larger companies an external auditor must independently agree. Most teams run this in spreadsheets and email, which is slow, hard to review and hard to defend.

This product replaces that. It gives the team one place to scope the work, test each control with its evidence attached, size any failure against a consistent threshold, drive the fix, and produce the paperwork. Every decision is recorded and every number is derived, never typed.

Success criteria

Goal	Measure
A full control test completes without leaving the product	Evidence, sample, results and sign off on one page
No conclusion without the evidence behind it	Steps locked until preconditions are met, with the reason stated
Two people grading the same failure agree	Severity computed from stated inputs, with the working shown
A reviewer can audit the audit	Every change attributed and timestamped, nothing silently overwritten

Year end paperwork is a by product	Working paper and report generate from testing already done

2 · Key terms

Term	Meaning
Test of Design (TOD)	Is the control built well enough to work? Read the documents, trace one transaction.
Test of Operating Effectiveness (TOE)	Did it actually work, every time, all year? Sample real transactions and check each one.
Population	The full set of transactions a control applies to, before you pick which ones to test.
IPE	Information Produced by the Entity. A report the company gave you, which must be proven before you build testing on it.
Materiality	The size of error that would matter to someone reading the accounts. The threshold every failure is measured against.
Deficiency	A control that failed. Also called an exception or a finding.
Material weakness	The worst grade. Open at year end means the company must publicly declare its controls ineffective.
Working paper	The audit file for one control. The proof that the testing was done properly.

3 · Personas and roles

Auditor Owns the testing. Scopes controls, sets the materiality ground rules, runs Test of Design and Test of Operating Effectiveness, validates the reports testing relies on, concludes each control, evaluates how bad each exception is, signs the working papers as preparer, and signs the engagement first.

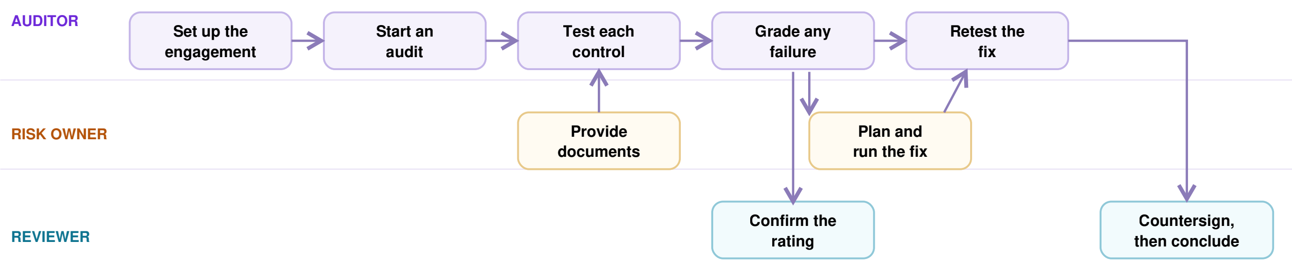
Reviewer The independent second pair of eyes. Works a queue of papers awaiting countersign, raises **review notes** (tracked challenges the auditor must resolve before a paper can close), verifies resolutions, closes exceptions after a passed retest, and countersigns the engagement to conclude it.

Risk / Control Owner First line, the person who runs the control day to day. Sees a scoped to do list, never the whole engagement: provide requested documents, **attest and evidence** due control tests, and execute remediation plans when something breaks.

Four eyes is person based, not just role based.
The product tracks *who* did each act. The same human cannot countersign a paper they prepared or close a retest they recorded, even wearing the reviewer hat. Every hand off is explicit: each control shows whose court the work is in.

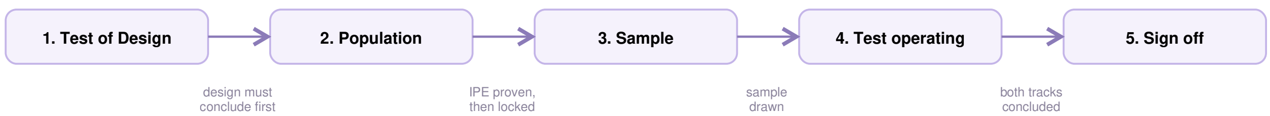
4 · User flows

FLOW A. THE FULL YEAR, END TO END



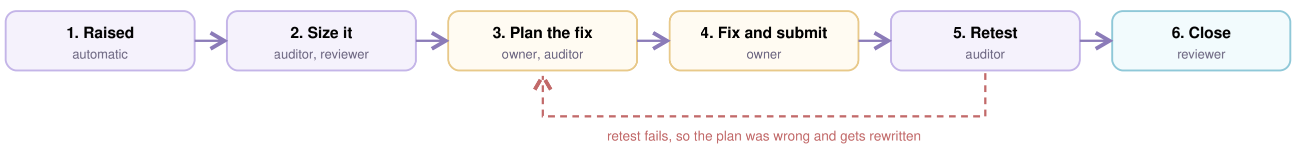
The audit team drives the spine. The business is pulled in twice, once for documents and once for the fix. The reviewer appears twice, once to confirm a serious rating before work starts and once to close it out.

FLOW B. TESTING ONE CONTROL



Each arrow is a gate, not a suggestion. The wording under it is what the product tells the user when the next step is still locked. Section 8 takes each step apart.

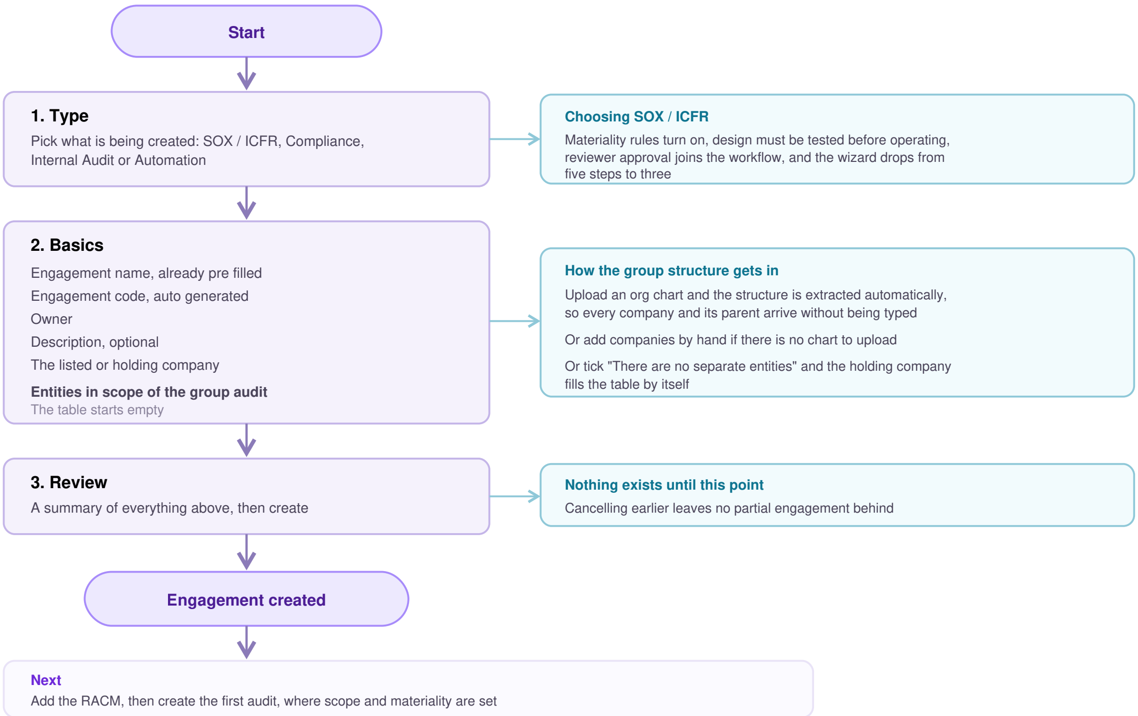
FLOW C. FIXING A FAILURE



A failed retest returns to planning, not to fixing. Two failures escalate to the reviewer, because at that point the problem is the plan, the owner or the rating, and not the fix. Section 9 takes it apart.

5 · Engagement creation

Reached from **Engagements, then New Engagement.** For a SOX / ICFR engagement it is **three steps**: Type, Basics and Review.



R5.1 DOCS ARE SHARED, RESULTS ARE NOT

RACM, control library, entities and people are defined **once per engagement** and consumed by every audit. Results, populations, samples and conclusions belong to **one audit only**. A new audit never disturbs a previous one's results.

R5.2 THE SAME CONTROL AT SEVERAL COMPANIES

One control tested at four companies appears as **four rows**, each with its own owner, due date, evidence and conclusion, sharing one control number. A failure at one company does not affect the others.

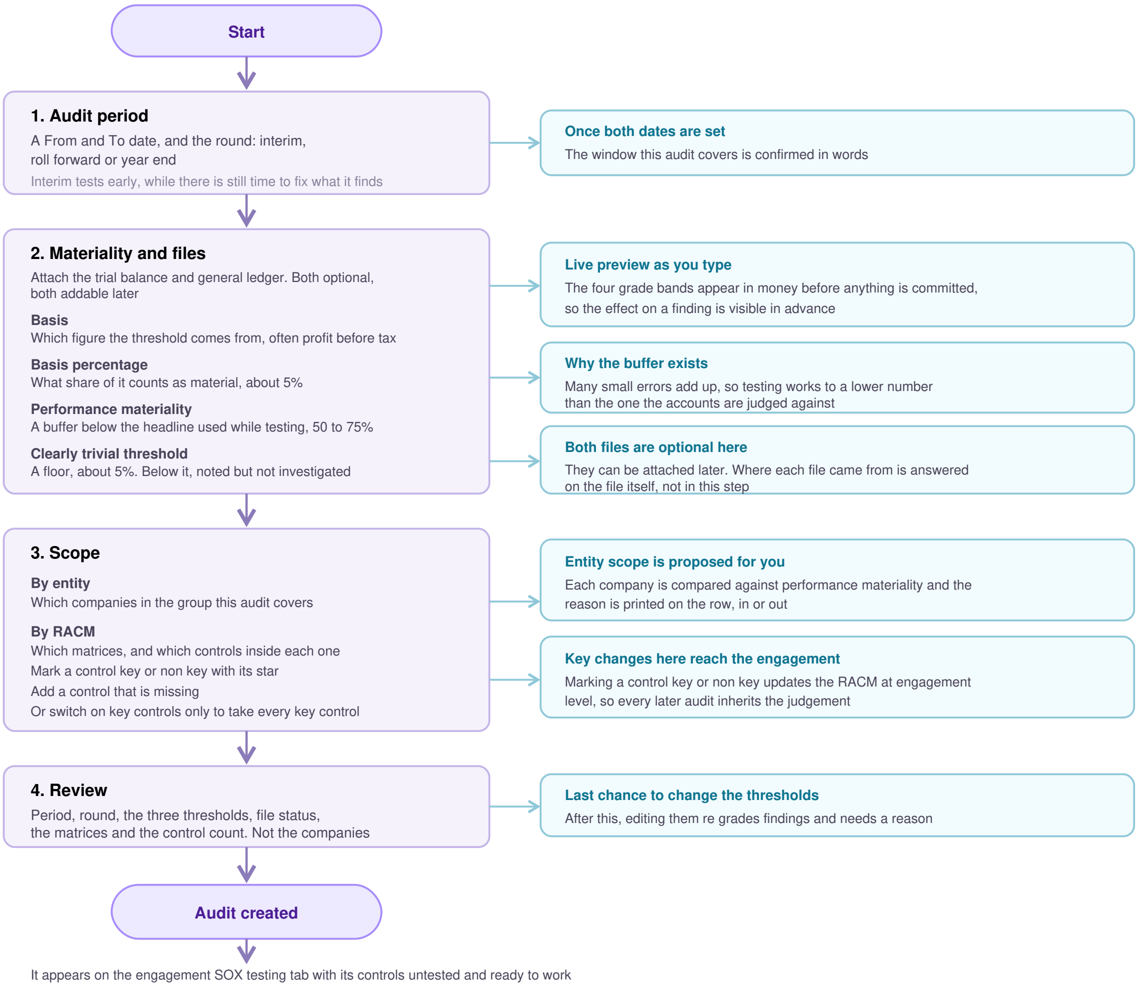
Edge cases

Situation	What should happen
The company is standalone with no subsidiaries	The tick box fills the entity table with the holding company itself and unblocks the step. No one has to invent a group structure.
The org chart upload does not parse	Fall back to adding companies by hand. The upload is a shortcut, never the only route.
The user abandons halfway	Nothing is created. The wizard can be cancelled at any point with no partial engagement left behind.
A non SOX type is chosen	

	The wizard keeps its longer path, because scope and the sign off chain have to be captured on the engagement itself, not on an audit.
A mandatory field is empty	Forward movement is blocked on that step, not at the end. The user finds out immediately, not after four more screens.
The engagement is created but has no RACM yet	The engagement opens on an empty state that says what is missing and links to it, rather than showing zeros as if testing had begun.

6 · Audit creation

Reached from **SOX testing, then New audit.** Four steps: Audit period, Materiality and files, Scope, Review. The thing created is an **audit**.



The files, and why they come first

Step 2 asks for the files before it asks for the numbers, because the numbers are read off the files. Two are offered, both optional at this point and both addable later.

File	What it is	What it decides
Trial balance	A summary of every account	The benchmark figure materiality is calculated from, and the per company balances that decide entity scope. It also decides who **can** be scoped: the org

	balance at a point in time	chart proposes the group, the trial balance qualifies it, and a company the trial balance does not name is greyed out and cannot be scoped in by anyone, because there is no data behind it to test. It stays on the engagement register for the next audit.
General ledger	The detailed record of every accounting transaction	The source most control populations are later drawn from, once a control reaches its population step

R6.1 SIZE IS NOT THE ONLY REASON TO TEST A COMPANY

Some companies matter for reasons a balance does not show: a recent acquisition, a system that went live this year, a history of errors, a business the group is unusually exposed to. Scoping one in on those grounds is a normal audit judgement and the product must allow it, not just tolerate it. The reason travels with the audit so a reviewer can see what the numbers alone would have missed.

R6.2 CHANGES MADE WHILE SCOPING REACH THE ENGAGEMENT

Marking a control key or non key, and adding a control the matrix was missing, both update the RACM at **engagement level**, not only this audit. The person scoping is the person who spots the gap, and whether a control is key is a judgement about the control itself, so every later audit inherits both instead of deciding again.

Edge cases

Situation	What should happen
A company sits below performance materiality but its parent is in scope	Warn explicitly. *"1 company is held by a company that IS in scope, but left out."* The auditor can still exclude it, but not by accident.
The auditor disagrees with the proposed scope	Any company can be toggled in or out. The proposal is a starting point, never a lock. The move is held until a reason is written.
A company is on the org chart but not in the trial balance	Greyed out, excluded, and not selectable. It stays on the engagement register so a later audit can pick it up.
A company is in the trial balance but not on the org chart	Shown as found in the data only and not on the engagement. It is visible, not silently dropped, so someone can go and fix the register.
The trial balance is removed after companies were toggled	The entities it introduced leave the list, and their overrides and reasons leave with them. A company with no row must not keep voting on the coverage total.
Group coverage falls below the target	The coverage meter shows it against the target and says so. It does not block, because the auditor may have a reason.
No trial balance or general ledger is available yet	Both uploads are optional and can be added later. Missing files must not stop an audit being planned.
An audit is created for a period that overlaps an existing one	Allowed, since interim and roll forward legitimately share a year, but the period coverage grid must show the overlap so it is visible.

Materiality changes after the audit exists	Treated as a dangerous act. See R7.2.

7 · Configuration

Every audit has its own settings screen. Edits save instantly and apply to this audit only, and the engagement's other audits keep theirs. Five blocks.

1. **Audit period.** Financial year (April to March) or calendar year (January to December), and which cycle this audit belongs to. The screen states the consequence: *"Testing runs Jan 2026 to Dec 2026."*
2. **What this audit covers.** Scope by company or by process, with the chosen processes ticked. The RACM and the control register follow it, so narrowing here narrows what the team sees everywhere else.
3. **Source files.** Every file this audit holds, in one list. Each shows its name, row count, which audit it belongs to, who added it and when, how many controls draw on it, and its origin, **System export** or **Client prepared**. This screen is a register, not an editor: **origin is read only here**, because it is answered once when the file enters the audit and changing it after testing has started would move the ground under work already concluded.
4. **Materiality and the severity ladder.** One block, not two. Basis, benchmark amount and percentage at the top, the three thresholds in money below, the four grade bands underneath in the same money. Changing the rule recomputes all of them, so the bands cannot drift out of step. The significant deficiency band is the one part adjustable on its own, as a percentage of materiality. How a grade is then arrived at is section 10.
5. **Policies and indicators.** Whether aggregation is on, and the five material weakness indicators.

> **R7.1 MATERIALITY BELONGS TO THE CYCLE, NOT THE ENGAGEMENT**
>
> Every round of the same cycle shares one materiality, and the engagement says so on the audit card: *"All 2 rounds of CY 2026 share materiality ₹12 Cr."* An interim and a year end testing the same year must be measured against the same number. What must never happen is a later cycle re grading a concluded one.

> **R7.2 SHOW WHAT AN EDIT WILL MOVE BEFORE IT LANDS**
>
> Materiality edits are a draft until applied. Applying must show **exactly which open findings in this audit change grade**, flag any promoted to material weakness, require a written reason, and write the change to a permanent log alongside the findings it moved.

Edge cases

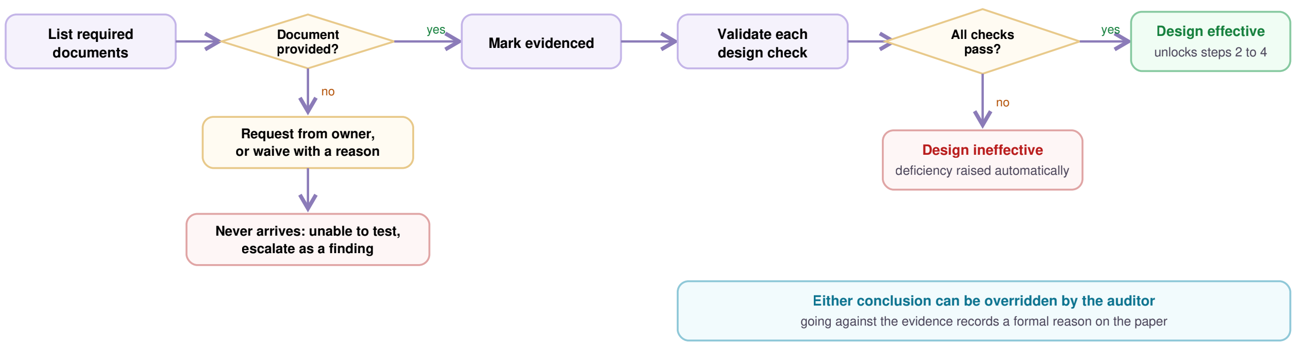
Situation	What should happen
A file's origin was answered wrongly	It cannot be corrected from here. The fix happens where the file entered the audit, and every control that already concluded on the old answer gets a review note. See R8.4.
Materiality is edited after testing has started	R7.2 applies. Other audits are untouched.
Aggregation is switched off part way through	

	Grades that were raised by aggregation fall back to their standalone value. This must be surfaced, not silent, because a material weakness could become a significant deficiency.
The significant deficiency band is moved	Every open deficiency re grades immediately. Same treatment as a materiality change.
Scope is narrowed after testing has started	Controls dropped from scope are archived, not deleted, so the work is not lost if scope is widened again.

8 · Testing one control

8.1 Test of Design

Is this control built well enough to work at all?



How it works

- **Design documents** arrive with the control, each marked required or optional. Usually a process description, a flowchart and a walkthrough. Each one is provided, waived with a reason, or requested. **Request data** emails the outstanding ones to the control owner, and each moves to **Requested** until something is attached.
- **Design checks** are the specific things that must be true for the design to hold. They come from the RACM, and each is validated on its own.
- **Checks are grouped, not one flat list.** The first group asks about the control as a whole: does it address the stated risk, and does it operate at sufficient precision. After that, one group for each attribute the control will later be tested against, so the design question and the operating question line up.
- **Each check has two evidence lanes. Evidenced by** links the client's documents. **Auditor's proof** is what the audit team produced itself. A check carrying only the client's document was read, and one carrying the auditor's own proof was tested. A whole set can be passed or failed at once, but the lanes still print per check.
- **The product proposes further checks** from the control's objective, its assertions and its nature. Each suggestion is accepted or dismissed one at a time, and nothing is inserted automatically.

R8.1 DESIGN CHECKS AND ATTRIBUTES COME FROM THE RACM

Both are defined once on the matrix and inherited by every audit that tests the control, so the same control is not re specified each cycle. Where the RACM carries none, the auditor can add them by hand on the control itself, and what they add flows back to the matrix instead of living only on this audit.

R8.2 CONCLUSIONS ARE SUGGESTED, NEVER FORCED

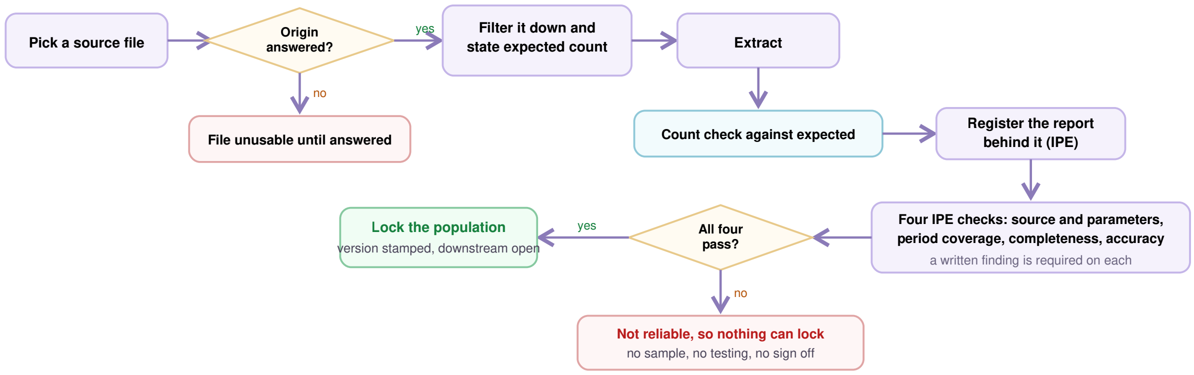
The product states what the evidence suggests and pre writes the reasoning. Concluding against it records a formal override with the auditor reason on the paper.

Edge cases

Situation	What should happen
A required document genuinely does not exist	Waive it, choosing one of three reasons: prepared by the audit team, held by the client and inspected in place, or not applicable. A written note is mandatory. A waiver counts as dealt with, not missing.
A document is requested and never arrives	Mark the control **unable to test**. The auditor records what is blocking it and what the owner must produce, and it routes to the process owner. Two exits: it arrives and testing resumes, or it never does and a finding is raised with the reason attached.
The evidence suggests effective but the auditor disagrees	They may conclude either way, but concluding against the evidence records a formal override with their reason on the working paper.
The control has no design checks defined yet	It cannot be concluded effective. The score reads 0%, and this must be distinguishable from a control whose checks all failed.
Only optional documents are missing	They do not block the conclusion. Optional evidence strengthens the file but never gates it.
A check passes on the client's document alone, with no auditor proof	Allowed, but the working paper prints the basis so a reader can see which checks were only read and which were independently tested.
The control is automated and the IT general controls hold	Steps 2, 3 and 4 do not apply. The control concludes on its design alone. The page must say which three steps are absent, why, and what would bring them back, because a short form paper that does not name its own precondition reads as work somebody skipped.
An IT general control fails after an automated control already concluded	The three steps come back and the conclusion is flagged for retesting. See section 8.3.

8.2 Population extraction

Before you can pick which transactions to test, you have to decide which transactions the control applies to at all. That set is the **population**. Getting it wrong quietly invalidates everything built on it, which is why this step ends in a lock.



The source file is picked **from the files already uploaded to this audit**. The expected count is stated *before* the extract runs, which turns it into a check rather than an observation.

A population can come from more than one file

One control often needs two extracts, because the year sits in two systems or two halves. So a population is a **named set built from one or more files**, and it carries its own reference and a total across all of them.

The rule that keeps it honest: **each file is proved on its own and sampled on its own, but the verdict is one for all of them.** A check that fails on any file sinks the whole population. Half a proven population is not a population.

Each file shows its own row, its own instance count, and its own state: done, or not drawn yet.

Extracting gives you a set of rows. It does not give you the right to use them. Before the population locks, the report those rows came out of is itself put under test. That test is called **IPE**.

IPE: proving the report first

IPE means **Information Produced by the Entity**: a report the company produced about itself. It is not trustworthy just because it arrived. It could have been run over the wrong months, with a filter nobody mentioned, or from a copy of the system rather than the live one. So the report is what gets tested here, not the transactions in it.

There is no form. The moment a population exists the audit already knows the report, because it is the source file, so the record is created from the file and the auditor arrives at the checks. If the wrong file was registered, **Withdraw** clears it and testing restarts.

Four checks

Check	What is being asserted	How it is proven
Source and parameters	The report was run from the live system over the audit period, with the filters this test assumes	Inspect the parameter screen capture and agree system, company code, date range and document types to the test scope
Period coverage	The extract spans the whole period, and an empty month inside it is the control not running rather than the extract stopping short	Agree the earliest and latest instance to the audit period. The screen shows the span and names every empty month but does not grade it, because arithmetic cannot tell a hole from a quiet month
Completeness		

	Every record that should be in the report is in it	Agree the count and control total to the system or the general ledger. A **Count it yourself** box takes the auditor's own count and shows the variance; **Write it up** turns it into the finding
Accuracy	What the report says about each record is true	Vouch a spot check back to source documents field by field, and re perform any calculated column

Concluding

- Pass and Fail stay disabled until a finding is typed, and what is written prints on the working paper.
- **One failure sinks the report.** Reliable is unavailable if any check failed, and neither verdict is available until all four are answered.
- Reopening a check drops the conclusion back to not tested.
- Only the auditor concludes. The owner attaches evidence but never grades it.

Three gates, not one

IPE is three separate gates at three points in the flow, not one check at one moment.

Gate	Where it sits	What it proves
The report is reliable	Inside population extraction, before the lock	The extract the population came out of can be relied on
Extraction is confirmed	After the sample is drawn	The drawn items trace back to the locked population, and the method and seed are on the paper
Evidence reports are proven	During operating testing	Any report the control itself reads is proven too. A perfect review performed over a wrong report is zero protection, so the control cannot be effective while the report it runs on is unproven.

Only a report concluded reliable lets the population lock. Locking stamps a **version**, and every later step draws off that version. A later round **re versions instead of editing**, so the earlier round's paper still shows the population it actually used.

> **R8.3 NO LOCK WITHOUT A PROVEN SOURCE**
> The population cannot lock until the report behind it is concluded reliable, and the sample, the testing and the sign off all sit behind that lock. **Not currently enforced. The live product allows a population to lock with the IPE untested.**

> **R8.4 CORRECTING A FILE'S ORIGIN REACHES BACK**
> Provenance is answered once on the file and inherited by every control using it. Changing it later updates all of them and raises a review note on any control that already concluded on the old answer.

Edge cases

Situation	What should happen

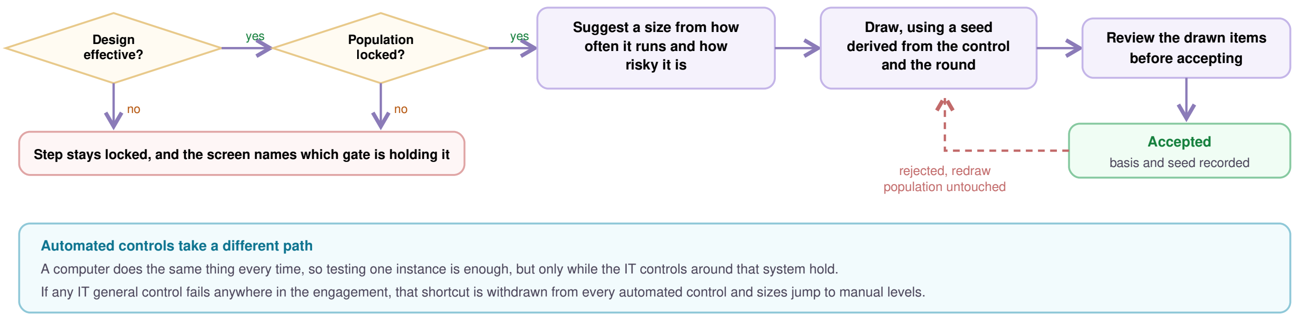
An attribute has a workflow mapped but no input file	Say which attribute, and offer to **ask the owner to upload it** from here. The auditor should not have to leave the control to unblock their own test.
The file has never had its origin answered	It cannot be used. The row is disabled with a tooltip saying to record where the file came from first. Provenance is answered on the file, once, not per control.
The extracted population is the same size as the source file	Warn that nothing was filtered out. Usually this means the filter was not applied, and the auditor is about to test the wrong set.
The count differs from what was expected	Show the variance. An overshoot and a shortfall are different problems and should not be reported identically.
The IPE fails a check	The report is not reliable. The population cannot lock, so the sample, the testing and the sign off all stay shut. The screen states this cascade rather than just disabling a button.
The IPE has not been tested at all	Same outcome as a failure. Untested is not the same as passed, and the lock stays closed.
The wrong file was used and testing has started	Withdrawing the population takes the sample and every result with it. Warn before doing it, naming what will be lost.
The filter was wrong but the file was right	Refiltering drops the extract and puts the old criteria back in the form, so the auditor edits instead of starting again.
A later audit needs a different window	The new audit creates a new version rather than editing the old one, so the earlier audit's paper still shows the population it actually used.

8.3 Sample drawing

You cannot check every transaction, so you check a handful that fairly stands in for the rest. Two questions decide it: **how many**, and **which ones**.

The population has already settled what "all of them" means. This step only picks from inside it, and never changes it.

Where the population was built from several files, **the sample is drawn per file**, each sized off the same band, and the step shows how many of the files have been drawn so far.



When this step opens

Two gates must both be green.

Gate	Why
Design is effective	A control that is not built right does not earn an operating test
Population is locked	A sample only stands in for a set that can no longer change

If either is shut, the step stays locked and the screen says which gate is holding it.

A seed is just a number that makes a draw repeatable. Same seed, same items. It is derived from **this control, this round and this file**, and stored on the paper with the ask, so a reviewer can reperform the draw and land on the same items.

The draw is asked for in a sentence

The sample step does not just take a number. For each file it holds a written instruction, drafted by the product and editable by the auditor, for example *"Take 4 of the 1,320 instances, one per period wherever the period has any, spread across the whole window."*

Underneath, the product says back **how it read the instruction**, and it is explicit when the answer is no longer random: *"4 items, chosen to fit the ask rather than at random, a targeted draw."* A targeted draw is allowed, but it must never be mistaken for a random one, and the paper records the ask itself alongside the result.

The suggested size stays visible beside the ask, with the band it came from, so a departure is obvious rather than hidden.

Automated controls, and the IT controls underneath them

A machine repeats itself, so one instance is enough. This is **test of one**. For a purely automated control it replaces the whole operating test: no population, no sample, no operating effectiveness. The design test is the test.

That reasoning is about the **system**, not the control. It holds only while the IT general controls hold.

When an IT general control fails

One IT general control concluded ineffective withdraws test of one from **every automated and IT dependent control in the engagement**. Not just the same system. Not just the same audit.

What changes	Detail
The operating test returns	Population, sample and operating effectiveness come back on controls that had concluded on design alone
The sample resizes	To the control's own frequency and risk band. A quarterly control does not become a daily one because an IT control broke
Prior conclusions are flagged	Anything concluded on one instance is marked for retesting
IT dependent controls are included	They never had the shortcut, but they lean on the same systems, so they carry the notice too

Where it is announced

The person who failed the IT general control was on another page. Elsewhere, a control grows three steps and its sample jumps. Unannounced, that reads as a bug. So it is said in six places, and each one **names the control that caused it**.

Where	What it says
Audit dashboard	A banner counting the affected controls, with the failed control named and linked
Control register	The same banner, plus an action that **sets the filter** to the affected set
Control library	The same again, so it lands with no audit open
Register saved view	A test of one withdrawn filter, present **only while a failure is in force**
Each affected control	A notice naming the culprit
The sample step	The size proposed, why, and that test of one returns once the culprit is remediated and retested

Auditor and reviewer only. Sample sizing is the audit team's method. The owner meets the consequence as data requests.

If a sampled item fails

A single failure does not end the test. The auditor decides whether it is a real pattern or a one off with a specific cause.

- Real pattern, or not sure: **draw more items** from the same locked population, same method, new seed saved.
- More failures in that batch: the control is ineffective, and an exception is raised.
- "One small miss, let it go" is not an option. Every failure is either explained on the record or carried into the conclusion.

What is saved

- Which population version the draw came from, and its locked count
- The size, the frequency and risk behind it, the ask as written, and any change with its reason
- How the items were picked, and the seed, plus the second seed if more items were drawn
- The items themselves, and who accepted them
- For automated controls: the system, its IT control state at the time, and whether one instance testing was used

Rules for drawing a sample

1. **Both gates green first.** Design effective and population locked. If either is shut, the step names the one holding it.
2. **The population is the set.** The ask selects within it and is recorded word for word. It can never widen the set, and a need to change the set means going back to fix the population.

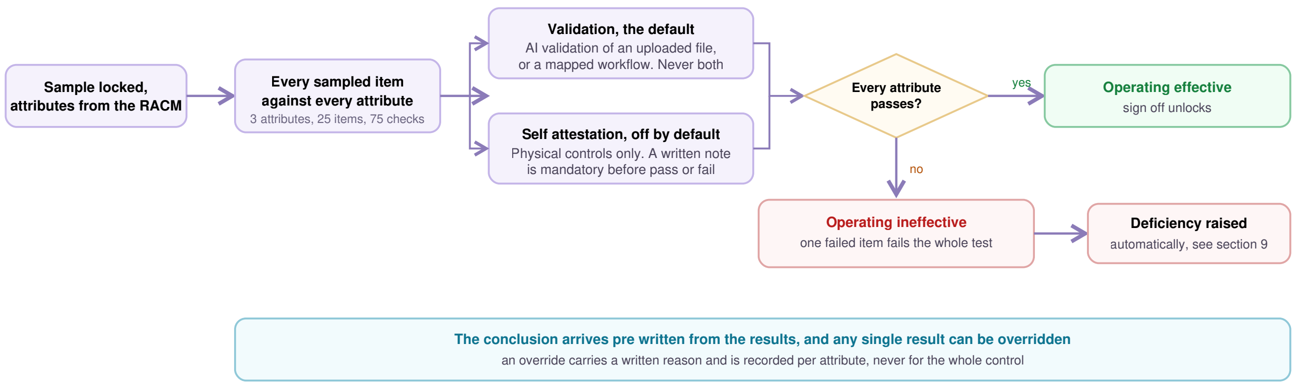
3. **Rejecting a draw never edits the population.** It draws again from the same locked set, with the new seed saved alongside the first.
4. **Frequency and risk come from the RACM.** Neither is asked for twice, and both are shown beside the suggested size.
5. **A failed IT general control withdraws test of one across the engagement.** Not per system, not per audit.
6. **The withdrawal is announced and names the culprit.** A control that grows three steps because of something done elsewhere reads as a bug otherwise.
7. **The paper is sized the way the screen was sized.** A working paper printing test of one against a screen showing twenty five contradicts the file it records.
8. **Every size, ask, method and seed is saved,** so someone who was not there can reperform the draw and land on the same items.

Edge cases

Situation	What should happen
The control runs on no fixed schedule	There is no band to read off. The size is a judgement call and the product says so rather than inventing a number.
The population is withdrawn after the sample was drawn	The sample and all its results go with it, with a warning naming what will be lost before it happens.
The suggested size is larger than the population	It is capped at the population. A sample cannot be bigger than the set it comes from.
The control has several paths and the draw lands on one	Flag it. A draw that never touched the second approval route has not tested the second approval route.
The ask is rewritten so the draw is no longer random	Allowed, but the product must say it is a targeted draw and the paper must carry the ask as written.

8.4 Test of Operating Effectiveness

Now the real question. **Did the control actually work, on every item you looked at?**



How it works

An **attribute** is one thing that must be true, for example that the second approver is a different person from the requester. Attributes come from the RACM, and each one carries its assertion, its precision and its procedure.

Self attestation is for controls whose only evidence is that a person went and looked: counting inventory, confirming a cabinet of signed contracts is locked, watching a reconciliation on site. The tester writes what they saw and attaches whatever the visit produced.

> **R8.5 SELF ATTESTATION IS FOR PHYSICAL CONTROLS**
> Attestation is the answer to a control whose evidence is an inspection performed in person, not a fallback for a control whose file was inconvenient to obtain. It is off by default, always secondary to validation, and where validation contradicts an attestation the validation stands.

Edge cases

Situation	What should happen
No file has been uploaded for AI validation	The run button stays disabled and relabels itself to say what is needed. *"Upload the required file first."*
No sample has been drawn	The control cannot be concluded effective, and the message points back to the sample step.
One item out of twenty five fails	That attribute fails, and so does the whole operating test. No partial credit.
The auditor disagrees with a result on one attribute	They can override it with a written reason, recorded per attribute, not for the whole control.
The only evidence available is somebody saying it happened	Inquiry alone is not enough for an operating conclusion. The product should refuse or flag it, because an attribute concluded on nobody's word is not tested.
The control is physical and produces no file at all	Self attestation is the intended route. The tester records what was inspected, where and when, and attaches whatever the visit produced.
Attestation is used on a control that does produce a file	Allowed but weaker, and the working paper must show that the attribute rests on a statement rather than on the document that existed.
The workflow run happened before the sample was drawn	Flag it as stale and require a re run. Results that predate the sample were not testing these items.
The owner attests but the validation contradicts them	The validation result stands. Attestation supports evidence, it does not overrule it.

8.5 Sign off and the working paper

When both tracks conclude, the control is finished and the paperwork that proves it becomes available. This is the step that turns testing into something a regulator can read.

What the working paper contains

The control and its objective, who owns it, the design documents and every design check with its proof, the IPE result, the population and its source, the sample with its method and seed, the full grid of every item against every attribute, the conclusion, the reasoning behind it, and both signatures.

Nothing in it is typed for the paper. Every line is read off the testing already done.

R8.6 THE PAPER IS A BY PRODUCT, NOT A TASK

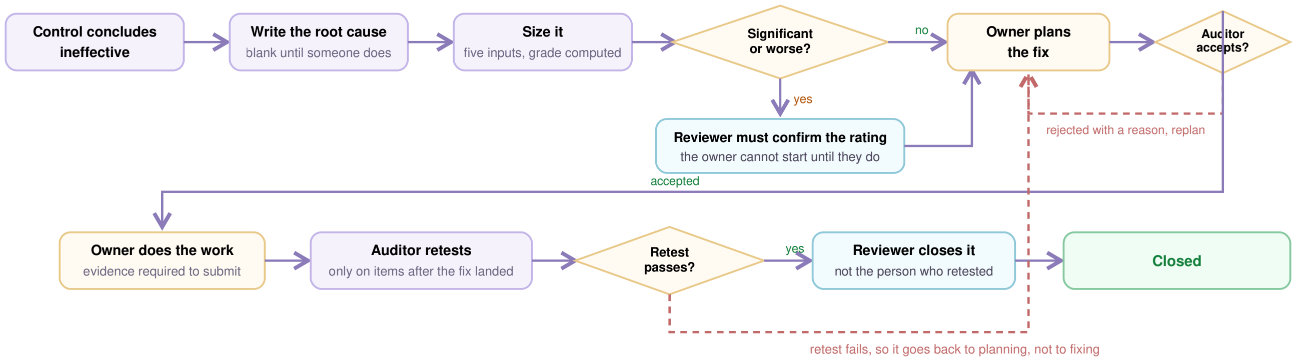
The working paper generates from the testing that has already happened. Nobody writes it. If a paper could say something the testing does not support, there would be two versions of the truth.

Edge cases

Situation	What should happen
The same person prepared and would countersign	Blocked, and the reason is stated by name, not by role. Wearing two hats does not make one person two people.
A review note is still open	Countersign stays blocked and the screen says how many notes must close first.
The reviewer is not satisfied	They return the paper instead of countersigning. Both conclusions are cleared, the reason is recorded, and the control goes back to the auditor. A returned paper without a reason costs the work twice.
Something needs changing after sign off	Reopening requires a written reason and is logged. Evidence, population, sample and results are kept. Only the conclusions and signatures are cleared.
The control concluded ineffective	It still gets signed off and still produces a working paper. Ineffective is a finished conclusion, not an unfinished one.
Someone wants the paper before testing is complete	It can be exported at any time, but it prints the true state, including what is still outstanding. A draft paper must not look like a finished one.
The whole round needs to be filed	An engagement level paper covers every control in one file, alongside a separate audit report written for management rather than for a regulator.

9 · Deficiency management

When a control fails, the finding is raised **automatically**. The auditor never creates one by hand, which is what keeps the register honest: every failure on the register traces back to a real conclusion.



Two failed retests escalate
At that point the problem is no longer the fix. It is the plan, the owner or the rating, and the reviewer is told so in those words.

The six steps

#	Step	Who	What happens
1	Raised	Automatic	Created from the failed control, with the failed items listed and the root cause left blank
2	Size it	Auditor, then Reviewer	Auditor sets five inputs and the grade computes. Significant or worse parks with the reviewer
3	Plan the fix	Owner, then Auditor	Owner writes what they will do, names themselves and a date. Auditor judges it against the root cause
4	Fix and submit	Owner	Owner does the work and attaches proof
5	Retest	Auditor	Fresh sample drawn only from after the fix landed
6	Close	Reviewer	Independent close, by someone other than the person who retested

The rule at each step

1. **Raised.** Created from the failed control, never by hand, so every finding traces back to a real conclusion.
2. **Size it.** While the finding is being sized the panel is live and editable, headed *"Severity inputs, recomputed live vs the ground rules"*. From the next step it becomes read only, headed *"Severity, evaluated by the auditor"*, and it also carries a **gap nature**, for example *"Operating failure, manual control"* or *"Design gap, manual control"*. The root cause starts blank and must be written before the finding can be sized. It has to say **why it happened**, the mechanism rather than the count. *"The payment run releases on the first authorisation and queues the second as an after the fact review"* is a cause. "9 of 40 payments failed" is not. A rating of significant or worse then blocks everything until the reviewer confirms it, because a wrong rating must not drive weeks of remediation.
3. **Plan the fix.** The owner writes it and names a date. The auditor judges it against the root cause and can reject with a mandatory reason, but **never writes or executes it**.
4. **Fix and submit.** The owner does the work, attaches proof, and is the only one who can declare it ready.
5. **Retest.** On a fresh sample drawn **only from after the fix landed**. Anything earlier came out of the broken control and proves nothing about the repair.
6. **Close.** The reviewer closes, and never the person who ran the retest.

Edge cases

Situation	What should happen
The exposure is below the clearly trivial floor	Logged and left alone. It is not evaluated, not aggregated, and does not consume anyone's time.
A rating the reviewer already confirmed changes later	Warn and demand re confirmation. *"The confirmed rating no longer matches. J. Fernandes confirmed this as Significant Deficiency; it now grades Material Weakness after combining with other exceptions."*
Someone tries to edit severity after the fix has started	Blocked. The inputs are editable through sizing and rating review, then read only. Re grading work already underway moves the goalposts on the person doing it.
The owner marks the fix done with no evidence	Submission is blocked. Done needs proof.
The control runs monthly and the fix landed in August	Say when a retest becomes possible rather than letting someone retest too early. *"Retestable from 15 Dec 2026. Fixed 15 Aug 2026 plus three to four monthly closes."*
The earliest possible retest falls after year end	Warn now, while the date can still move. A fix that cannot be proven before the opinion date is a problem to raise in August, not December.
The control runs annually	There is no second occurrence to sample this year. Say so plainly and carry it forward rather than pretending a retest is coming.
The retest fails	Back to planning, not to fixing. If the fix did not work, the plan was wrong. Every attempt is kept with the reason it failed.
The retest fails twice	Escalate to the reviewer with different wording, because the problem is now the plan, the owner or the rating.
The person who retested tries to close it	Blocked. Closing is the reviewer's act, and independence is the point.
The business disputes the exposure or likelihood	They can raise a formal challenge on the input rather than the grade, since the grade is computed. The auditor must respond with a reason either way, so the argument lands on the paper instead of in a corridor.
The year ends with the finding still open	An open material weakness at year end means ICFR is declared ineffective. The countdown must show this every day until it closes.

10 · How severity is decided

Grade	Meaning	Consequence
Clearly trivial	Too small to investigate	Logged and left alone
Deficiency	Real but small	Tracked and fixed

Significant deficiency	Senior people must know	Escalated, with the rating confirmed by the reviewer
Material weakness	The numbers could be wrong in a way that matters	Reportable. Open at year end means controls are declared ineffective

The five inputs

Input	Asks
Likelihood	How plausible was it that something slipped through? Remote, Reasonably possible, or Probable
Exposure	**What could have slipped through while the control was broken, not the error you found.** The most misunderstood field in the product
MW indicators	Five red flags, such as fraud by senior management
Compensating control	Another control partly covering the same risk
Prudent official	Auditor judgement that it is worse than the maths says. Where the grade is already material weakness the screen says so: *"already at the top of the ladder, nothing to raise."*

The seven rules, in order

#	Rule	Effect
1	MW indicator present?	Yes gives **Material weakness**, whatever the amount. Stop
2	Compensating control available?	Only if that control is itself tested effective. Held for later
3	Below the clearly trivial floor?	Yes gives **Clearly trivial**. Stop
4	Likelihood more than remote?	Remote caps it at **Deficiency**, however large
5	Exposure ladder	At or above materiality gives material weakness. At or above the significant band gives significant. Below gives deficiency
2b	Apply the cap	Lowers material weakness to significant by one step, never to nothing
6	Aggregation	Combine with findings sharing an **account line item** or an assertion, then re run the ladder. **Can only raise.** A material weakness indicator or an ITGC exception does not aggregate on one account
7	Prudent official	The auditor may raise with a mandatory reason. Never lower

R10.1 SEVERITY IS COMPUTED, NEVER TYPED

No field stores a hand set grade. Change an input and the grade recomputes.

R10.2 THE ENGINE SHOWS ITS WORKING

Every rule the engine reached prints a line, **including rules that changed nothing**, and the reader can see where it stopped. A finding carrying an indicator prints two lines and stops: the indicator that decided it, then *"No cap available, an indicator cannot be argued down by another control."* Rules the engine never reached are not shown, because a rule that did not run is not part of the reasoning.

R10.3 A FAILED CONTROL NEVER LEAVES THE REGISTER

Only one rule lowers a grade, the compensating control, and it drops it by one step. Nothing takes it to zero. *"Capping Material Weakness to Significant Deficiency, never clears the exception."*

R10.4 CHANGING THE GROUND RULES IS A DANGEROUS ACT

Materiality and the significant deficiency band are set per audit and can be edited from Configuration for the life of that audit. Editing either re grades every open finding in the audit, so it is treated as a draft until applied, and applying it follows R7.2.

---

11 · Confidence scores

Seven read outs, four on the engagement and three on a control. All computed live from the evidence. None is stored, so none can drift or be set by hand.

Every one is a percentage of the same shape, a count of what is done over a count of what there is.

$$\text{score} = \frac{\text{done}}{\text{total}} \times 100$$

Engagement level

1. RACM completeness

Is the matrix approved to test against?

$$C_{\text{racm}} = \frac{a}{n} \times 100$$

a = RACM rows approved · n = controls in scope · reads `{a}/{n} rows approved · {r} remarks open`

One RACM row is one control, so the denominator is the scope itself. A remark is a blocker with a named condition, not a half approval, so *r* sits beside the score and never enters *a*.

2. Control effectiveness

Are the controls working?

$$C_{eff} = \frac{e}{n} \times 100 \quad \text{and red whenever } x > 0$$

e = controls where *both* tracks concluded effective · x = controls concluded ineffective · reads `{e}/{n} controls effective · {x} ineffective`

Either track ineffective sinks the control, so *e* counts agreement between the two. Colour is not proportional here: one ineffective control turns it red whatever the percentage says.

3. Sample testing

How much of the testing ground is covered?

$$C_{samp} = \frac{\Sigma\, d_i}{\Sigma\, t_i} \times 100 \quad \text{where } t_i = s_i \times k_i$$

d_i = checks run on control *i* · t_i = checks the control has · s_i = sample size · k_i = attributes · sums run over every control in scope

The two sums are taken before the division, not after, so each control weighs by its own check count. Where no sample has been drawn yet, t_i falls back to k_i so the denominator is never zero.

4. Engagement completeness

How much is finished?

$$C_{comp} = \frac{\Sigma\, m_i}{n} \times 100 \quad \text{where } 0 \le m_i \le 1$$

$$m_i = 0.10r + 0.25g + 0.30o + 0.25c + 0.10f$$

m_i = milestone credit for control *i*, each term 1 when done and 0 when not · r RACM row approved · g design concluded · o operating concluded · c paper countersigned · f no open deficiency

The five weights sum to 1, so every control is worth exactly one whole unit however far along it is. A short form automated control has no operating track to conclude, so its 0.30 moves onto *g* instead of leaving it stuck below 1.

Control level

5. Control completeness

Is the evidence file complete? **Blocks concluding design.**

$$C_{ctrl} = \frac{q}{Q} \times 100$$

Q = design elements marked required · q = of those, evidenced or waived · reads `{q}/{Q} required elements evidenced`

Optional elements are outside *Q* entirely, so attaching extras cannot move the score. A waived element counts inside *q*, because a recorded judgement with a mandatory reason is not a missing file.

6. Evidence validated

Have the operating checks run? **Blocks concluding operating.**

$$C_{val} = \frac{d}{t} \times 100 \quad \text{where } t = s \times k$$

Same terms as score 3, for one control instead of the register

Score 3 says how much ground is covered across the audit. This one says where the shortfall sits.

7. TOD coverage confidence

How well does the design hold up? Does not block.

$$C_{tod} = \frac{p}{D} \times 100$$

D = design considerations on the control · p = of those, passing · reads `{p}/{D} considerations pass`

An overridden pass counts inside *p*, because the auditor's recorded judgement is the answer. Untested and failed both sit outside it, so an untested check drags the score down exactly as hard as a failed one. It is the only quality measure of the seven, and it gates nothing.

Colour

One rule, applied to every score.

$$\text{colour}(x) = \text{red if } x < 40, \quad \text{amber if } x < G, \quad \text{green if } x \geq G$$

G = 100 for a gating score, 80 for the rest · scores 5 and 6 gate, so nothing but 100 is green on them

12 · Glossary

Term	Meaning
Aggregation	Combining small findings that share a cause and judging them together
Assertion	What a control protects about the numbers: complete, accurate, real, right period
Attribute	One specific thing checked on each sampled item
Compensating control	A different control partly covering the same risk
COSO 2013	The recognised framework for what good internal control looks like
Detective control	Catches a problem after it happens
General ledger	The detailed record of every accounting transaction
ICFR	Internal Control over Financial Reporting
IPE	Information Produced by the Entity, a company produced report that must be proven before it is relied on
ITGC	IT General Controls: access, change management, operations. Scoped by declaration rather than derived from the trial balance, and tested once for the group.
Key control	A control that really matters for the numbers, not merely good practice
Population	The full set of transactions a control applies to
Preventive control	Stops a problem before it happens
Provenance	Where a file came from, and whether the company or its system produced it
RACM	Risk and Control Matrix
Roll forward	Carrying interim testing forward to cover the rest of the year
SOX 404	The section requiring an annual statement that internal controls work
Test of one	Testing a single instance of an automated control, on the argument that a machine does the same thing every time. Valid only while the IT general controls hold.
Trial balance	A summary of every account balance at a point in time
Walkthrough	Following one real transaction end to end to confirm a control exists and makes sense
Working paper	The audit file for one control